



Encrypting Stored Data, Certificates on Services, and Proving That Encryption Works

- Lesson 1 — Encryption of stored data (local and cloud)
- Lesson 2 — Applying certificates to a service: HTTPS on the intranet
- Lesson 3 — Validating that encryption is really in place
- Running example: NorthMaple Accounting Inc. • prepares LAB_06 Part 2

The model drafts. The analyst decides. The analyst's name goes on the record.



Today's three questions

- A NorthMaple laptop is lost at an airport — what stops the finder reading the client files?
- The intranet still runs on plain HTTP — how do we move it to HTTPS with no public CA, today?
- Once it is all encrypted — how do we PROVE it, with evidence a second person can check?

Acceptable use and the law

- All material is for defensive education inside your own isolated laboratory
- Practice only on systems you own or hold written permission to test
- Fictional company, fictional data — no real client, salary or password anywhere
- Unauthorized access is a crime: Criminal Code s.342.1, s.342.2, s.430(1.1)
- Governed by the Legal Notice, Disclaimer and Acceptable Use Policy v1.0

Where we are: Classes 15 and 16

- Class 15 — a certificate is a public key + identity, signed by a CA
- Class 15 — a self-signed certificate is its own issuer; trust it only after checking it
- Class 16 — a VPN builds an encrypted tunnel; WireGuard authenticates each peer by its key
- Class 16 — encryption in transit protects data while it MOVES
- It does nothing for a file on a disk — today's first subject

Encryption of stored data

- 1 Data at rest, and what encrypting it does
- 2 Five layers, local to cloud
- 3 Keys, recovery and cryptographic erase
- 4 Encryption in cloud storage



Three states of data

- Data in transit — moving on a network (Class 16, the VPN)
- Data in use — in the memory of a running program
- Data at rest — stored on a medium not being processed (NIST SP 800-111)
- Today: data at rest — disks, files, backups, cloud objects
- Cipher: AES (FIPS 197) • XTS mode for disks • GCM mode for files

What encryption at rest protects — and what it does not

PROTECTS when the medium leaves your control:

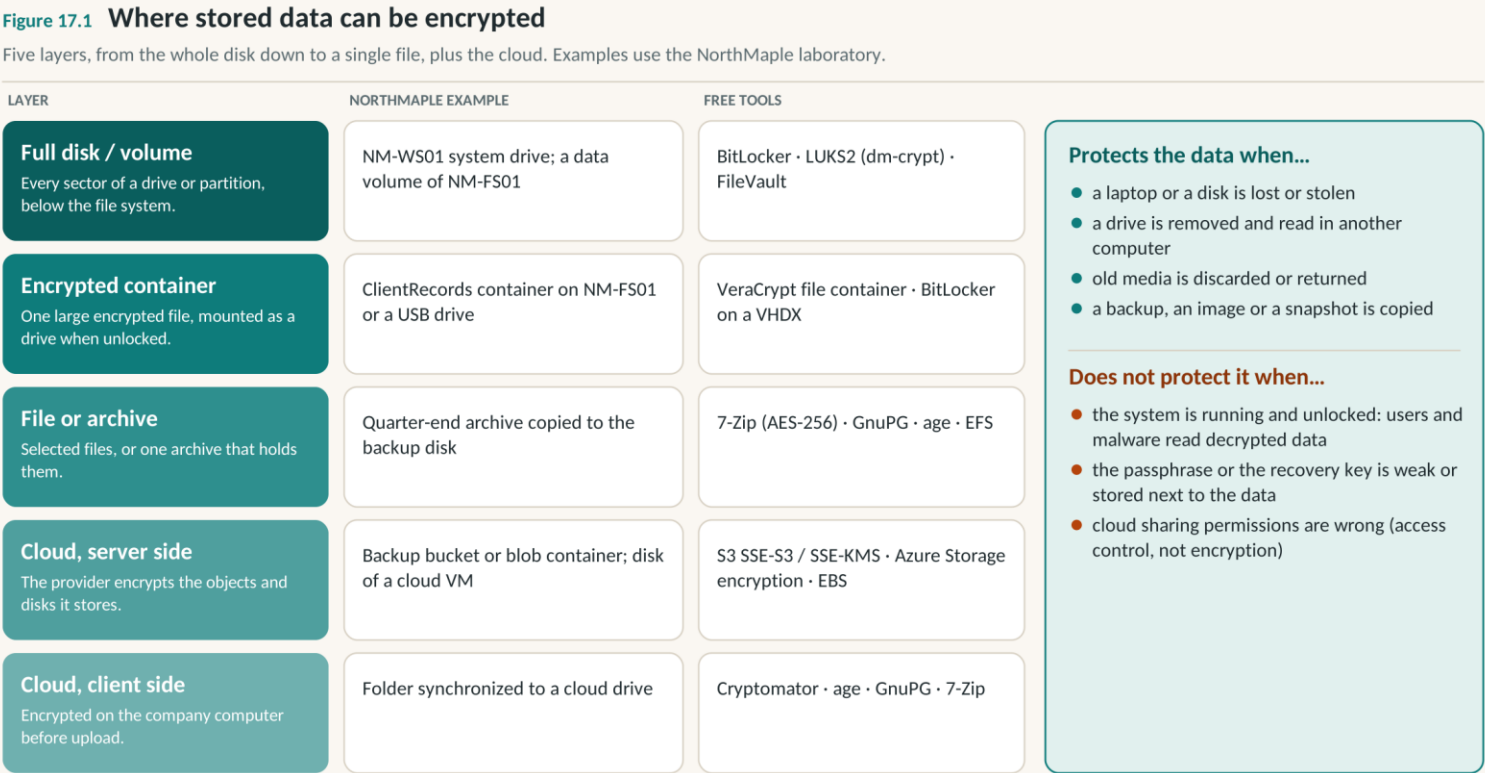
- lost or stolen laptop
- disk pulled from a server
- returned leased machine
- copied backup or stolen snapshot

DOES NOT protect a running, unlocked system:

- the OS decrypts for authorized programs
- a logged-in user (or its malware) reads files
- not a substitute for access control
- CIS Safeguards 3.6 and 3.11

Five layers where stored data can be encrypted

Figure 17.1 — the five layers with NorthMaple examples and free tools.



Cyber.SoHo · Cyber Defense (420-D03-AB) · Class 17 · Laboratory figure, fictional company · © 2026 Cyber.SoHo

The three local layers

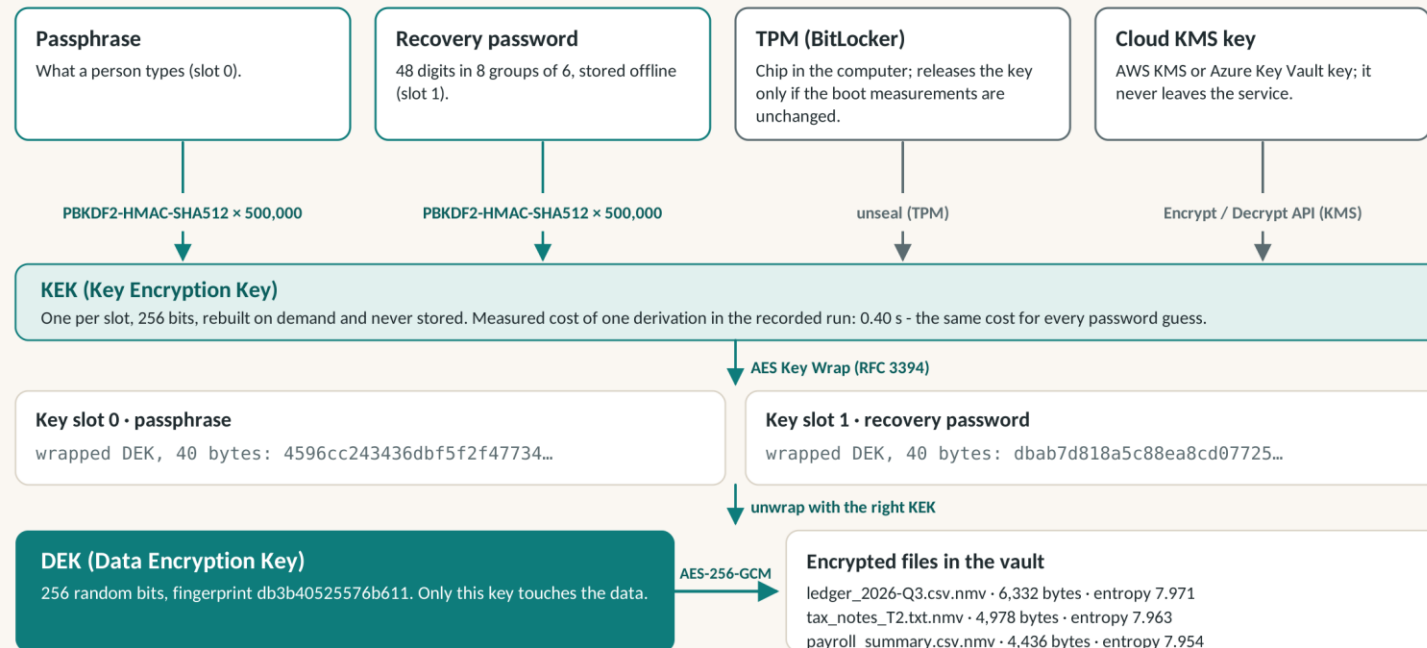
- Full disk / volume — BitLocker (XTS-AES 128, raisable to 256), LUKS2, FileVault
- Encrypted container — VeraCrypt: one file, mounts as a drive when unlocked
- File / archive — 7-Zip (AES-256), GnuPG, age
- Encrypt the empty volume first, then write data in — avoids leftover plaintext
- At rest and in transit are complementary, not alternatives

Envelope encryption: one DEK, several key slots

Figure 17.2 — secrets → KEK → wrapped DEK → data, with recorded values.

Figure 17.2 Envelope encryption: one DEK, several key slots

The pattern behind BitLocker protectors, LUKS2 keyslots, VeraCrypt headers and cloud KMS. Numbers from the recorded run of nm_envelope_vault.py.



Change a passphrase: only its 40-byte slot is rewritten; the encrypted files stay identical. Destroy every slot: the data can never be decrypted (cryptographic erase).

Cyber.SoHo · Cyber Defense (420-D03-AB) · Class 17 · Laboratory figure, fictional company · © 2026 Cyber.SoHo

Deriving a key from a passphrase

- A passphrase becomes a KEK through PBKDF2 (NIST SP 800-132)
- Salt — the same passphrase gives a different key on each system
- Iteration count — a fixed cost per guess (recorded: ≈ 0.40 s per derivation)
- BitLocker, LUKS2 (argon2id) and VeraCrypt all use this idea
- Strong passphrase + slow derivation = a stolen disk is impractical to open

Recovery and cryptographic erase

Recovery (plan for a lost passphrase):

- BitLocker 48-digit recovery password
- LUKS2: up to 32 key slots
- stored separately from the data
- never on the same disk as a note

Cryptographic erase:

- destroy every wrapped copy of the DEK
- ciphertext becomes permanently unreadable
- no need to overwrite the medium
- NIST SP 800-88 Rev. 2 (purge)

Cloud: shared responsibility, then server-side vs client-side

- Shared responsibility: provider secures the cloud; you configure protection of your data
- Server-side: S3 SSE-S3 (default since 2023) / SSE-KMS; Azure Storage encryption (always on, AES-256)
- Current: S3 SSE-C blocked by default for new buckets since April 6, 2026
- Server-side protects against a stolen data-centre disk, not against the provider
- Client-side (Cryptomator, age): encrypt before upload — unreadable to the provider



NorthMaple's encrypted vault

► Feeds a future lab — this example becomes a LAB_06 Part 2 deliverable

Scenario

Client records on NM-FS01 are copied to a backup disk that leaves the building. If it is lost, can the finder read them?

Task

Build an encrypted vault (AES-256-GCM, one DEK, two key slots) and measure the result.

Becomes in LAB_06

The data-at-rest deliverable of Part 2 — Chapter 6 (2 of 15 pts) + Manual 6.1–6.4.

nm_envelope_vault.py — the recorded run

nm_envelope_vault.py

What it does

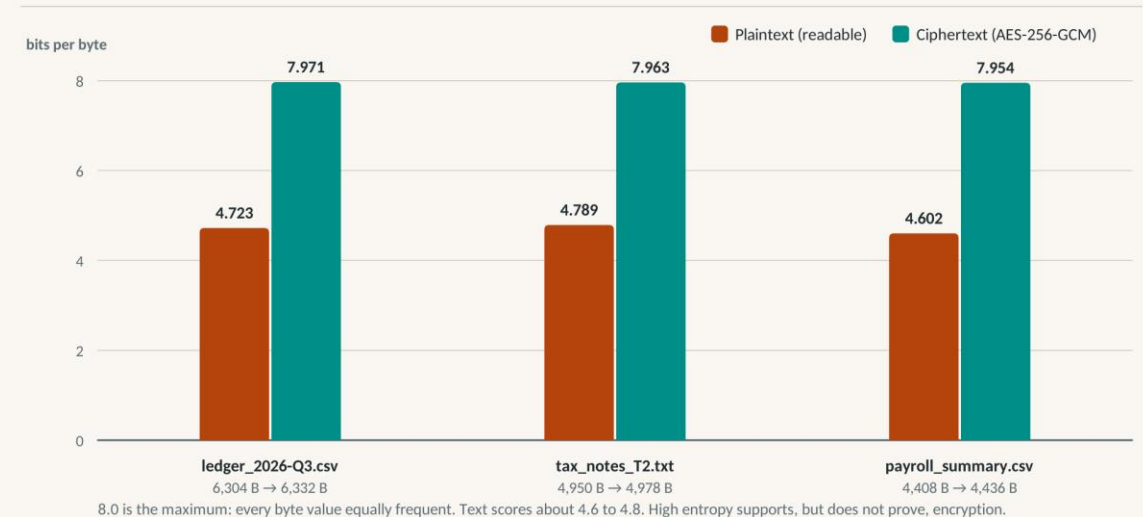
Create the fictional client-records folder, encrypt it with envelope encryption (one DEK, two key slots), and run the six proofs: plaintext readable, ciphertext unreadable, wrong passphrase refused, recovery works, tampering detected, passphrase change re-wraps the key only.

In the page

The live player reproduces this recorded run step by step; press Start, then Step and Pause to walk it with the class.

Figure 17.3 Entropy before and after encryption

Shannon entropy of each NorthMaple record, plaintext and ciphertext (recorded Lesson 1 run).



Cyber.SoHo • Cyber Defense (420-D03-AB) • Class 17 • Laboratory figure, fictional company • © 2026 Cyber.SoHo

Applying certificates to services

- 1 Why an internal service needs HTTPS too
- 2 The certificate: self-signed, right names
- 3 Serving HTTPS only, protecting the key
- 4 Distributing trust and registering



Internal is not the same as safe

Over plain HTTP on the wire:

- the page, the login, the cookie
- every click, in clear text
- readable by any host on the segment
- network zoning is not confidentiality

TLS adds three things at once:

- encrypts the traffic
- authenticates the server
- detects tampering
- TLS 1.3 (RFC 9846); 1.0/1.1 deprecated

Self-signed, because no public CA will issue

- An internal name (intranet.northmaple.internal) cannot get a public certificate
- CA/Browser Forum Baseline Requirements forbid it; Let's Encrypt needs a public name
- Two correct choices: a private CA (Class 15) or a self-signed certificate
- Self-signed = its own issuer (Subject = Issuer); no third party vouches for it
- LAB_06 uses the self-signed path — done correctly

Anatomy of the intranet certificate

Figure 17.5 — every field of the recorded self-signed certificate.

Figure 17.5 Anatomy of the intranet certificate

X.509 version 3, self-signed, created by nm_https_enable.sh on Oct 10, 2026 · 592 bytes in DER form.

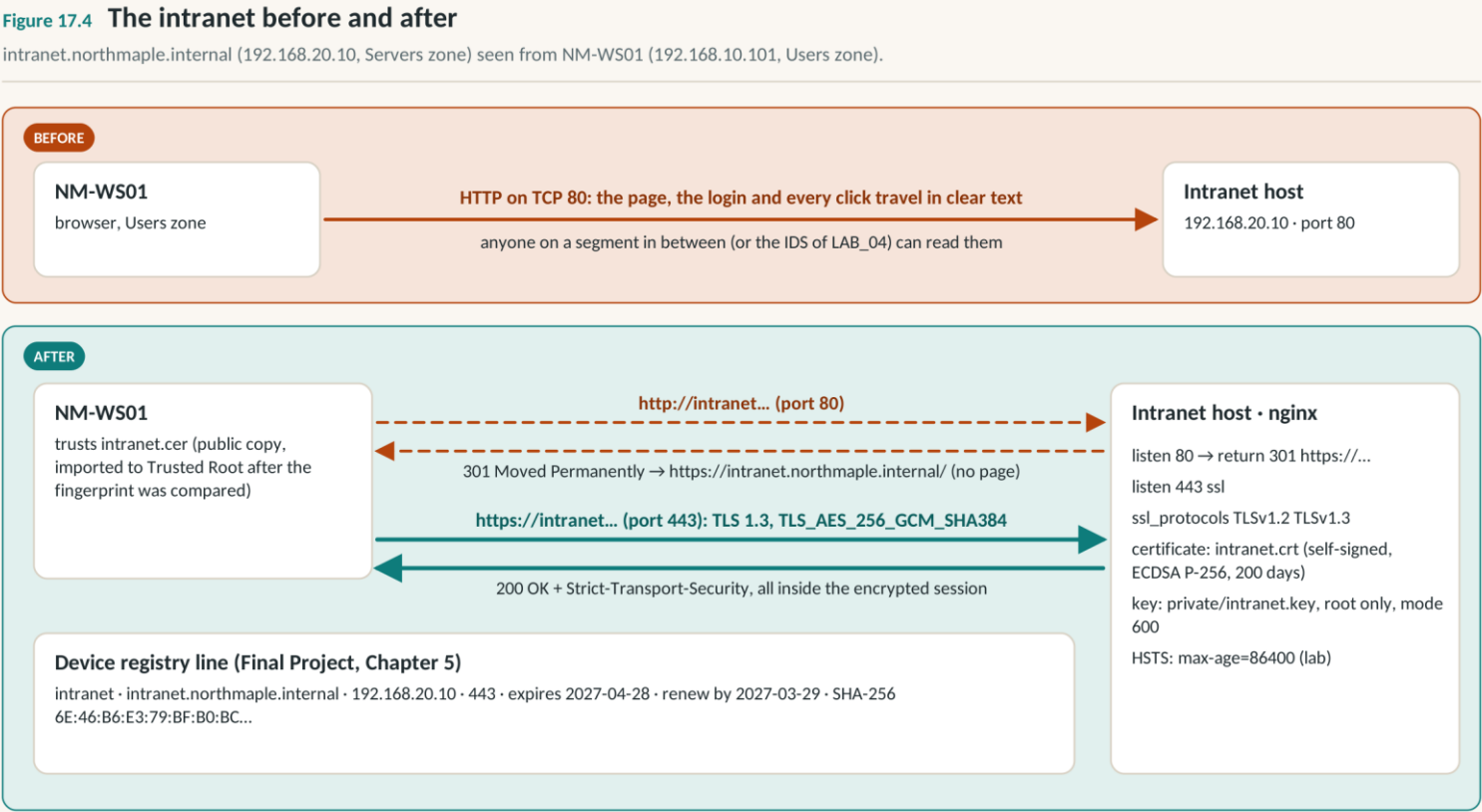
Field	Value in intranet.crt (recorded run)	Why it matters
Subject	O = NorthMaple Accounting Inc. (LAB), CN = intranet.northmaple.internal	Who the certificate names.
Issuer	O = NorthMaple Accounting Inc. (LAB), CN = intranet.northmaple.internal	Identical to the subject: self-signed.
Serial number	1a:28:15:8b:d3:c4:17:f2:83:cf...	Random, unique per certificate.
Validity	Oct 10 11:57:06 2026 GMT → Apr 28 11:57:06 2027 GMT	200 days; plan the renewal.
Public key	id-ecPublicKey, 256 bit, curve P-256	The key clients use in the handshake.
Signature	ecdsa-with-SHA256	Signed with its own private key.
Subject Alternative Name	DNS:intranet.northmaple.internal, IP Address:192.168.20.10	The only names clients accept.
Basic constraints	CA:FALSE (critical)	Cannot sign other certificates.
Key usage	Digital Signature (critical)	Only signatures (TLS 1.3).
Extended key usage	TLS Web Server Authentication	serverAuth: valid for a server.
SHA-256 fingerprint	6E:46:B6:E3:79:BF:B0:BC:83:D7:0A:92:C8:CF:EF:62...	Compared before trusting; stored in the registry.

The fields that make it correct

- Subject Alternative Name (SAN) — the only names a client accepts; the CN is ignored (RFC 9525)
- Basic Constraints CA:FALSE — may not sign other certificates
- Extended Key Usage serverAuth — valid to authenticate a server
- Validity 200 days — the public maximum since March 15, 2026 (100 in 2027, 47 in 2029)
- Created with OpenSSL (supported: 3.5 LTS, 3.6, 4.0)

The intranet: from HTTP to HTTPS only

Figure 17.4 — before (HTTP) and after (301 on 80, TLS on 443).



Cyber.SoHo · Cyber Defense (420-D03-AB) · Class 17 · Laboratory figure, fictional company · © 2026 Cyber.SoHo

Serve HTTPS only, and guard the private key

- Port 80 — return 301 to https:// and serve no page, login or cookie
- Port 443 — present the certificate, accept only TLS 1.2 and 1.3, add HSTS
- Private key — root-only directory, key file mode 600, certificate 644
- The key is generated on the server and never leaves it; copy only the certificate
- Recorded test: TLS 1.3 with TLS_AES_256_GCM_SHA384

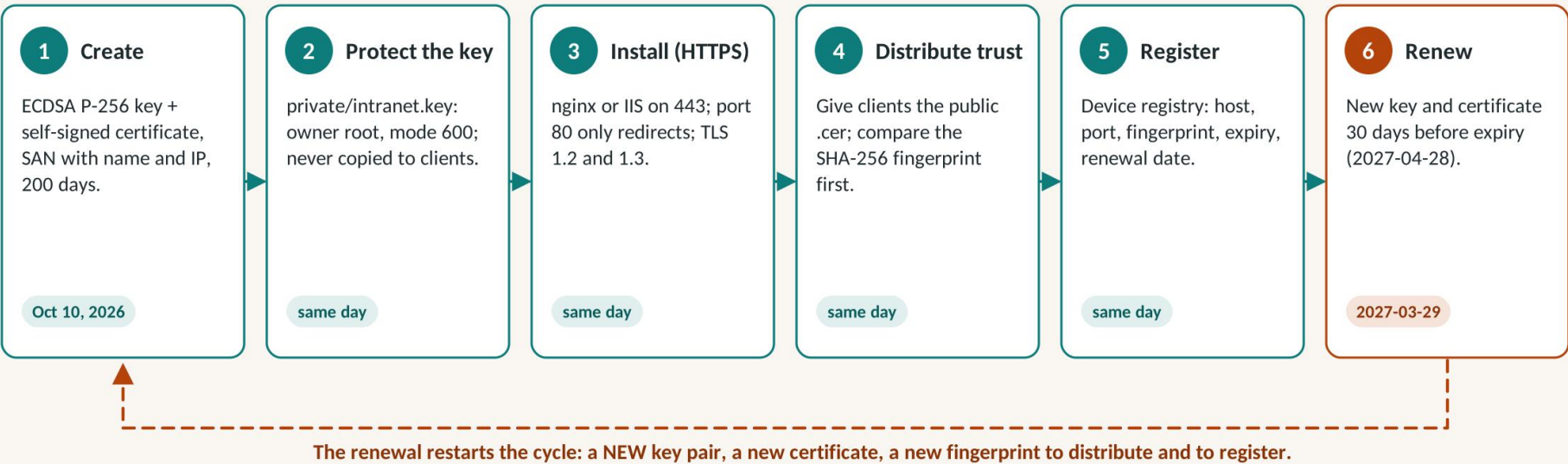
Distribute trust by fingerprint, then register

- An untrusted client refuses the certificate — the warning is CORRECT
- Fix it by installing the certificate, after confirming it
- Confirm it by its SHA-256 fingerprint, compared out of band (recorded: 6E:46:B6:E3:79:BF...)
- Distribute only the public .cer; the private key never travels
- Register it: host, port, fingerprint, expiry, renewal date 30 days earlier

Life cycle of the certificate

Figure 17.6 — create, protect, install, distribute, register, renew.

Figure 17.6 Life cycle of the intranet certificate
The steps LAB_06 asks for, with the dates of the recorded run; the cycle restarts before the expiry date.



Move the intranet to HTTPS only

► Feeds a future lab — this example becomes a LAB_06 Part 2 deliverable

Scenario

NorthMaple's intranet (192.168.20.10) runs on plain HTTP.

Task

Self-signed ECDSA P-256 certificate with the right SAN, HTTPS only, key root-only, verified with s_client.

Becomes in LAB_06

The HTTPS deliverable — Manual 6.3 Procedure + the Chapter 5 registry row.

nm_https_enable.sh — the recorded run

nm_https_enable.sh

What it does

Generate the self-signed key and certificate with the right SAN and extensions, configure nginx for HTTPS only with a redirect on port 80, protect the private key, and run five tests that prove the result (plain HTTP redirects, untrusted client refused, trusted client gets 200 + HSTS, TLS 1.3 negotiated, loaded config shows TLS 1.2/1.3 only).

In the page

The live player reproduces this recorded run step by step; press Start, then Step and Pause to walk it with the class.

- One OpenSSL command: key + self-signed certificate with SAN, CA:FALSE, serverAuth
- nginx: 80 → 301, 443 serves with TLS 1.2/1.3 + HSTS
- Five tests: HTTP redirects, untrusted refused, trusted 200 + HSTS, TLS 1.3, config check

Validating that encryption is really in place

- 1 Why validation is a step of its own
- 2 Validating data at rest
- 3 Validating HTTPS
- 4 Validating the tunnel

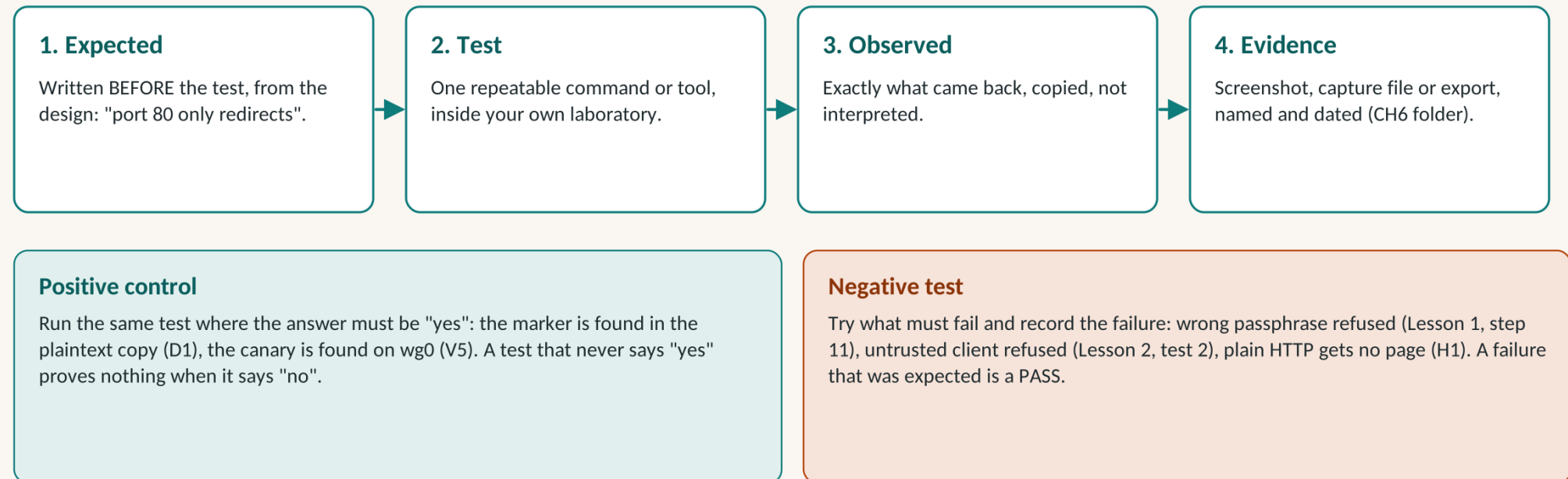


How a validation is built

Figure 17.11 — expected, test, observed, evidence; positive control and negative test.

Figure 17.11 How a validation is built

The structure of section 6.4 of the manual: expected → test → observed → evidence, plus two kinds of control.



Cyber.SoHo · Cyber Defense (420-D03-AB) · Class 17 · Laboratory figure, fictional company · © 2026 Cyber.SoHo

Claims, evidence, and two controls

- A checkbox, a padlock, "connected" are claims, not evidence
- Validation: expected (first) → test → observed (exact) → evidence (named, dated)
- Positive control — the same test where the answer must be "yes"
- Negative test — try what must fail; an expected failure is a pass
- This is section 6.4 of the Course Procedure Manual

Validating data at rest

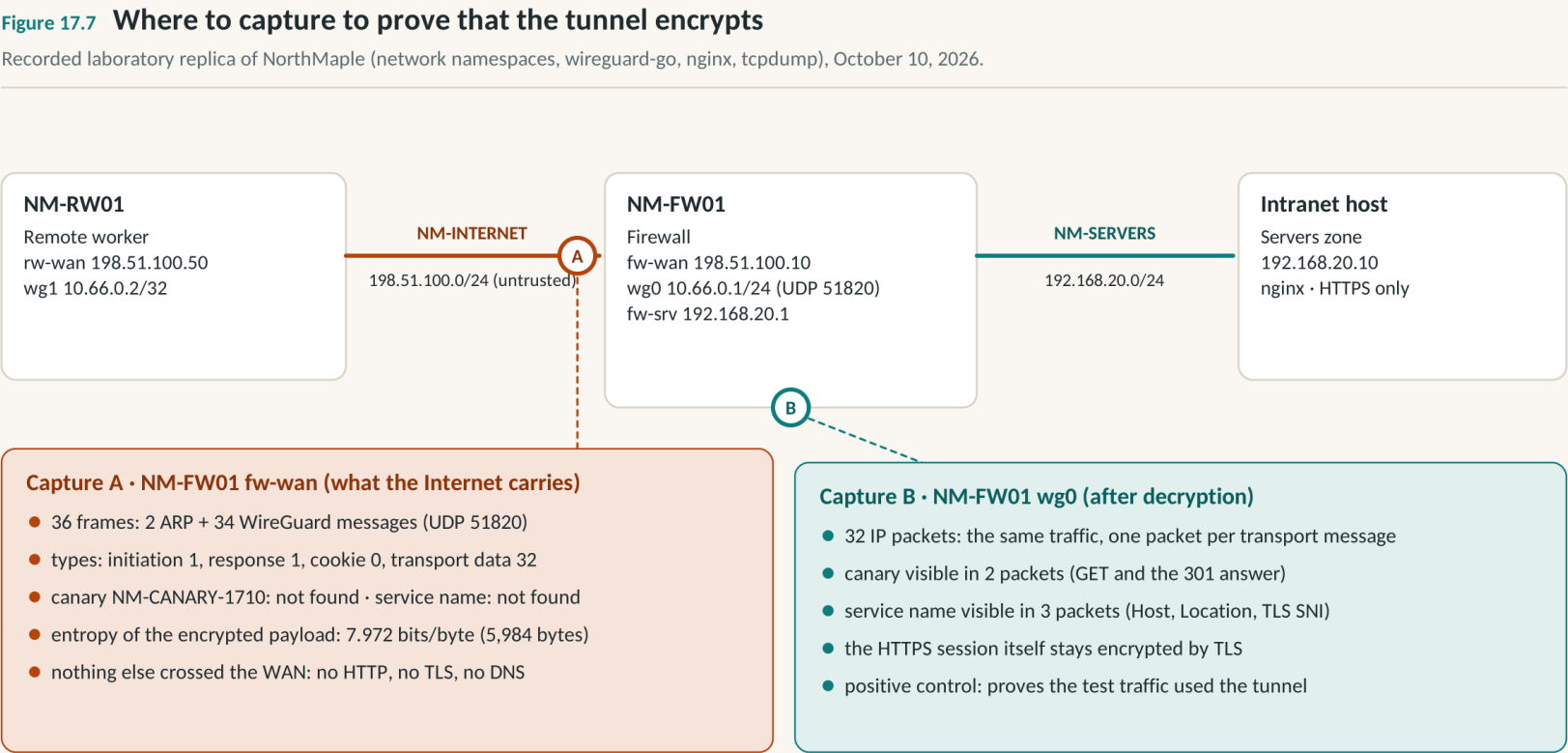
- Marker test — unique string found in plaintext (3/3), absent from ciphertext (0/3)
- Entropy — ciphertext ≈ 7.99 bits/byte (max 8.0); text ≈ 4.6 –4.8
- Entropy supports but does not prove — compressed data also scores high
- Strongest: wrong passphrase refused, right one opens and matches (a screenshot)
- The marker and entropy tests support the manual one

Validating HTTPS

- Negative test — HTTP gets 301, never the page
- TLS session — version 1.2/1.3, cipher suite recorded
- Fingerprint — the presented certificate matches the registry byte for byte
- Host name — accepted only because the name is in the SAN (set in Lesson 2)
- HSTS header present; testssl.sh / nmap confirm TLS 1.0/1.1 are refused

Where to capture to prove the tunnel encrypts

Figure 17.7 — the two capture points on NM-FW01 and the recorded counts.



Cyber.SoHo · Cyber Defense (420-D03-AB) · Class 17 · Laboratory figure, fictional company · © 2026 Cyber.SoHo

Figure 17.8 Same packet, two views: WAN capture vs tunnel capture

Capture A - fw-wan (Internet side)

156 bytes · WireGuard type 4 (transport data)
clear header: receiver index 0x95d1dd2e, counter 1

```
0000 fc 75 7f e0 1a d1 e4 2e 46 a8 19 1e 47 98 a0 49
0010 fe 55 8c 6e c5 3b 44 1c 58 39 8e 46 29 e6 a2 df
0020 07 da 09 f6 98 25 30 fd c0 58 d9 2b f3 33 53 9d
0030 39 e1 39 9c b8 c7 51 38 33 e2 cc dc d3 03 01 8e
0040 71 1a 82 c0 af 48 f4 15 b3 5b e7 58 92 bb 98 a6
0050 ee a0 e2 c0 29 25 c9 57 55 84 92 6c f2 ff a2 23
0060 3a a7 50 ed 22 59 6a 5a 68 ec 2b 82 94 a2 75 17
```

canary: NOT FOUND • service name: NOT FOUND

ICMP 10.66.0.1 → 10.66.0.2

84 bytes inside = 96 after padding → 156 bytes outside
content: ping (ICMP echo)

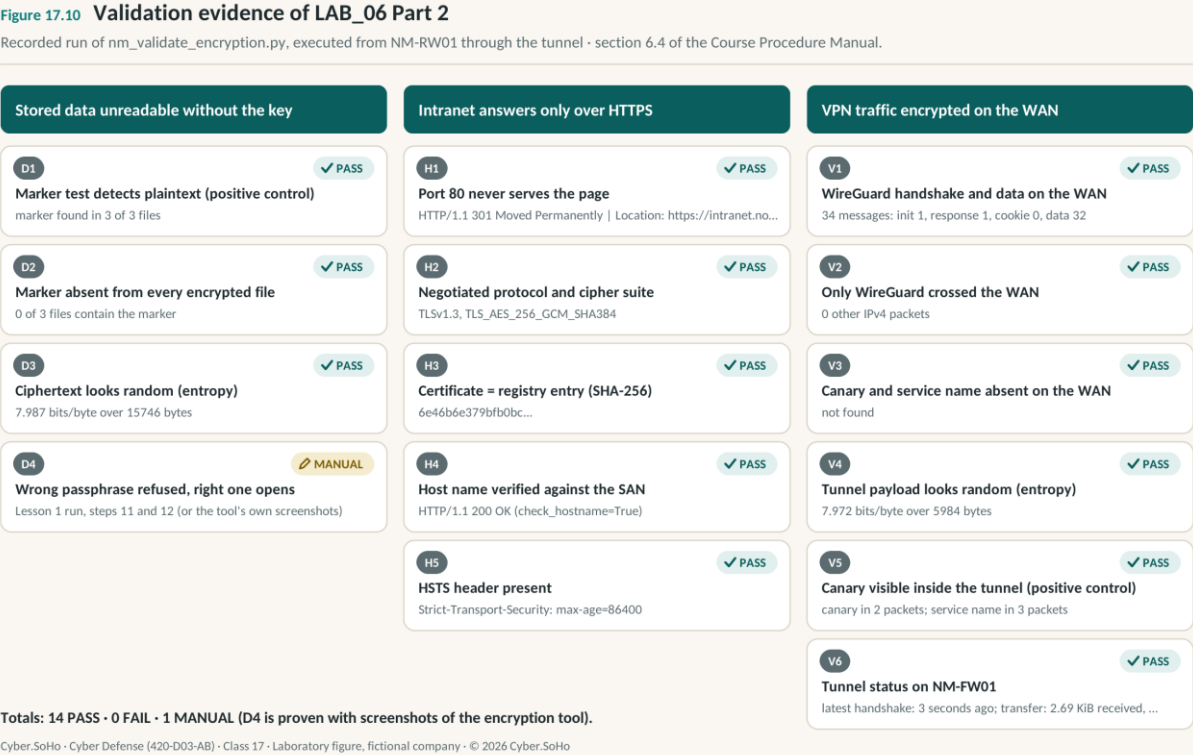
```
..8I...(.j.....?.....!"#
$%&'()*+,-./01234567
```

canary: not in this packet • service name: not in this packet

"Show me it is encrypted"

► Feeds a future lab — this example becomes a LAB_06 Part 2 deliverable

Figure 17.10 — the fifteen validation results.



nm_validate_encryption.py — the recorded run

nm_validate_encryption.py

What it does

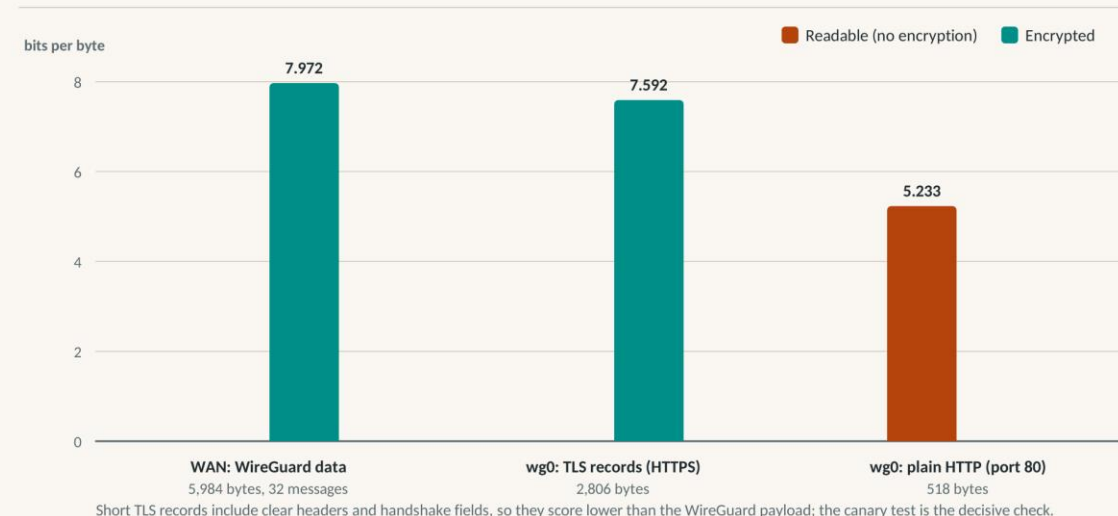
Run every validation of LAB_06 Part 2 in one pass — data at rest (marker, entropy, manual key test), HTTPS (redirect, TLS version, fingerprint vs registry, host name, HSTS), and the tunnel (read the two capture files for WireGuard-only, canary absent on WAN and present on wg0, plus wg show) — and write a dated evidence table.

In the page

The live player reproduces this recorded run step by step; press Start, then Step and Pause to walk it with the class.

Figure 17.9 Entropy of the captured payloads

Same test traffic seen at the two capture points of NM-FW01 (recorded Lesson 3 run).



Cyber.SoHo • Cyber Defense (420-D03-AB) • Class 17 • Laboratory figure, fictional company • © 2026 Cyber.SoHo

LAB_06 Part 2 — what you will do (1/2)

Part 1 — remote-access tunnel:

- WireGuard on NM-FW01 (pfSense/OPNsense)
- keys, users, allowed networks for NM-RW01
- connection verified through the sim-Internet

Part 2 — encryption and validation:

- one folder/volume encrypted (Lesson 1)
- HTTPS with a self-signed cert (Lesson 2)
- validation of all three (Lesson 3)

LAB_06 Part 2 — deliverable (2/2)

- Chapter 6 of the Final Project (2 of 15 points) and of the Course Procedure Manual (1 of 10)
- Sections 6.1 Objective to 6.6 AI disclosure, standard template
- Today's three examples become the vault, the HTTPS service and the evidence table
- AI rule (Legal Notice s.11): state the LLM and the exact prompts
- The model drafts. The analyst decides. The analyst's name goes on the record.

Summary and what is next

- L1 — encrypt stored data (AES-XTS/GCM); envelope keys; recover; erase by destroying keys; cloud server-/client-side
- L2 — HTTPS on an internal service; self-signed cert with the right SAN; HTTPS only; protect and register the key
- L3 — validate: expected/test/observed/evidence, with a positive control and a negative test
- Next: the work period is LAB_06 (both parts); Quiz 03 (scope: Classes 15–17) is created for the next class
- Answer the three opening questions — laptop safe, intranet on HTTPS, all of it proven



End of Class 17

All links verified October 10, 2026 — scan with VirusTotal before opening in class

Governed by the Legal Notice, Disclaimer and Acceptable Use Policy v1.0

The model drafts. The analyst decides. The analyst's name goes on the record.

